〔NEXUS WORK 조 회의록 및 활동일지〕 2026.10.27(화)

■ 활동 날짜 및 참여 조원

· 날짜: 2026-10-27(화), 개별 작업 + Notion 작업 보고서 공유

· 참여: 진혜정(조장), 홍주형, 이시헌, 김태빈

■ 오늘의 목표

· AI-XDR 파이프라인의 핵심 버그(/ai-xdr/process가 계속 processed=0으로 남는 문제) 원인 규명 및 해결

· 네트워크·탐지·자동화 각 영역에서 어제 이어서 할 수 있는 점검·개선 작업 진행

■ 조원별 활동 내역

▶ 진혜정 (자동화·n8n·AI 판정 설계 / 팀 상황판)

· 어제(10/26) 설계한 AI-XDR 확장 작업을 이어가려 했으나 n8n은 김태빈 전담으로 확정, 포털(192.168.3.10/.14:5070)도 curl 직접 테스트에서 여전히 timeout 확인 — 역할 범위를 재정리

· Graylog 이벤트 정의 〔NEXUS〕〔R5〕 계정 스프레이(card(user)〉4)가 서버 오류 "No series handler registered for: cardinality"로 한 번도 정상 작동한 적 없음을 규명, 이시헌의 개별 테스트 룰로 교차 검증해 Graylog 서버/플러그인 레벨 버그로 특정

· R1~R12 전체 이벤트 정의를 감사해 card() 함수를 쓰는 규칙이 R5 하나뿐임을 확인, 결과를 정리해 김태빈에게 전달

· 계획서 역할 D(팀 상황판) 표를 재확인 — 전 항목 10/18~10/23 날짜로 완료 상태임을 확인

· 팀 GitHub 저장소(stulss/nexus-work)를 읽기 전용으로 클론해 ZAP 2.17.0 스캔 알림 3건을 조사 — 세션 쿠키(nexus_session)는 이미 HttpOnly·SameSite=Lax·Secure(환경별 조건부)가 올바르게 설정돼 있음을 확인, 조치 불필요로 결론

▶ 홍주형 (포털·DB 하드닝)

· /ai-xdr/process가 계속 processed=0으로 남아 AI 판정(assessment)이 생성되지 않는 문제의 원인을 읽기 전용으로 추적

· 대상 이벤트의 조회 쿼리는 정상 선택되는데도 이후 단계에서 조용히 실패하는 것을 발견 — security_xdr_assessments의 외래키 제약을 INSERT IGNORE가 삼켜 "0행 삽입"으로 처리되며 에러 로그도 남기지 않는 것이 근본 원인임을 확정

· 팀원이 병합한 수정(ecb528a)으로 존재하는 티켓 id만 남기도록 고쳐졌고, 재시작 후 assessment_id가 정상 연결됨을 확인(해결 확인)

· 점검 중 추적되지 않던 더미 데이터 스크립트를 커밋·푸시하면서 하드코딩된 DB root 비밀번호를 발견해 환경변수로 교체

· 남은 문제: 티켓이 .14 DB에 생성되지 않는 현상(DB_BIND가 127.0.0.1로 고정돼 있고 .15↔.14 방화벽 규칙이 Block 상태인 것이 원인으로 추정), R1 이벤트가 승인 대상(〔"review"〕)도 자동 차단 대상(AU

TO_BLOCK_RULES)도 아니어서 PENDING 상태에 막혀 있는 정책 문제

▶ 이시헌 (네트워크)

· pfSense 전체 서비스 상태 점검 — 전부 정상

· XDR 자동 차단 파이프라인 2개 경로(n8n→/block API, 포털→XDR_BLOCKED_IPS 피드) 모두 정상 작동 확인

· 방화벽 룰(WAN/LAN)·Suricata 설정을 전체 감사해 급한 문제는 없음으로 결론(개선 여지 5가지는 별도 기록)

· ntopng admin 비밀번호가 재부팅 후 풀리는 문제의 원인(Redis 직접 수정이 config.xml에 반영 안 됨)을 파악해 GUI 경유 재설정으로 영구 해결

· WAN 80포트(HTTP) 룰 생성 출처를 확인해 본인 PC(VMnet2)임을 확인, 발표용으로 pfSense 개념·원리 정리

▶ 김태빈 (탐지)

· 운영 DB 덤프로 processed=0을 유발하던 stale incident_ticket_id(FK) 문제를 독립적으로 재현·수정, processed=1 및 assessment-event 연결 확인(홍주형과 같은 버그를 서로 다른 경로로 교차 확인)

· synthetic R1 이벤트로 Graylog→n8n→Ticket→AI-XDR assessment 전체 흐름을 검증 — AI 판정은 SUSPICIOUS/75점이었으나 승인 불가인데 PENDING으로 반환되는 문제를 발견

· 로컬 R1 정책을 승인 불가 시 NO_ACTION으로 맞추고, n8n 후보의 하드코딩된 〔"review"〕 조건을 제거 — 관련 테스트 89개 통과

· Ticket DB(.15)와 AI-XDR DB(.14)가 분리돼 있어 assessment-Ticket 연결이 끊기는 문제를 확인(운영 Published v3는 변경하지 않음)

■ 조원별 의견 및 제안 사항

· 진혜정: 공식 역할 분담이 끝난 뒤에도 네트워크가 막혀 있을 때는 독립적으로 조사·검증할 수 있는 영역(탐지 룰 감사, 보안 스캔 검토)을 스스로 찾는 게 전체 진행에 도움이 됨

· 홍주형: "로그에 에러가 없다"는 정상의 증거가 아니며, INSERT IGNORE처럼 실패를 조용히 삼키는 패턴을 항상 의심해야 한다는 교훈

· 이시헌: 설정 변경이 GUI를 거쳐야만 영구 반영되는 경우가 있어(ntopng), 설정 파일 직접 수정보다 관리 UI 우선 확인이 더 안전함을 확인

· 김태빈: 정책값(승인 조건 등)이 코드 상수로 고정돼 있으면 운영 중 유연한 조정이 어려움 — 정책과 코드를 분리해 둘 필요성을 체감

■ 회의 결과 및 결정 사항

1. AI-XDR processed=0 버그는 해결 확인(홍주형·김태빈 양쪽에서 교차 검증 완료)

2. R1 승인 정책(현재 〔"review"〕만 승인 대상, 자동 차단 대상도 아님)을 어떻게 바꿀지는 추가 논의가 필요해 결정 보류

3. Ticket DB(.15)·AI-XDR DB(.14) 분리 문제는 방화벽 → DB_BIND → n8n 자격증명 순서로 변경을 합의하기로 함

4. Graylog R5 집계 버그는 김태빈이 서버/플러그인 레벨에서 확인하기로 함

■ 프로젝트 진행 상황 및 어려운 점

· 진행 상황

- AI-XDR 핵심 버그(processed=0) 해결, R1 E2E 흐름까지 확인됨
- pfSense·네트워크 쪽은 안정적으로 유지, 자동 차단 파이프라인 정상 작동 확인
- 팀 GitHub 저장소 보안 점검(ZAP) 결과 특이사항 없음, 계획서 역할 D 항목 전부 완료 재확인

· 어려운 점

1. 서버 간(.14/.15) DB 분리로 인한 데이터 정합성 문제가 티켓 연결·R1 정책 등 여러 영역에 걸쳐 영향을 줌
2. 포털(192.168.3.10/.14:5070)이 외부에서 계속 접속 불가해 수동 공격 테스트 등 일부 작업이 보류 중
3. R1처럼 승인도 자동 차단도 안 되는 "막다른" 정책 상태가 존재해 정책 재설계가 필요함

■ 향후 활동 계획 및 역할 분담

· DB_BIND·방화벽·n8n 자격증명 변경 순서 합의 후 순차 적용(홍주형·이시헌)

· R1 승인 정책 결정 및 코드·테스트 반영(김태빈)

· Published v3에 R1 후보 수정 반영 후 pending→approve_response dry-run 검증, 이후 R2~R12 E2E 진행(김태빈)

· 포털 복구되는 대로 kali-attack-checklist.md 기반 IDOR·SSRF·세션 쿠키 변조·간접 인젝션 수동 테스트 재개(진혜정)

· Graylog R5 버그 서버/플러그인 레벨 조치(김태빈)

■ 증거 자료

· 조원별 작업 보고서: 팀 Notion '회의 및 작업내용'(10/27) 페이지

- 진혜정 - 10/27 작업 / 2026-10-27_회고록(홍주형) / 10월 27일자 작업 보고서(이시헌) / 2026-10-27 작업 기록(김태빈, 개인 워크스페이스)

· 로컬 파일(홍주형): XDR_process_processed0_점검결과.md, nexus_db_dump_20261027_1442.sql